Berner Fachhochschule
Haute école spécialisée bernoise
Bern University of Applied Sciences



IAM

IAM-Modelle

Prof. Dr. Annett Laube, HS 2026, HSLU

Taxonomien

IAM-Modelle lassen sich nach verschiedenen Kriterien einteilen:

1. **Benutzersicht**: Wer stellt die Identität aus und wer kontrolliert sie?

2. **Topologie**: Verteilung der einzelnen IAM-Komponenten auf Systeme mit potenziell anderer Organisationszugehörigkeit

3. **Data Flow**: Federation vs. Provisioning

4. **(Einteilung nach Zielgruppen und Einsatzgebieten:** B2E, B2C, B2B, …)

Übersicht

- Taxonomien
  - Modelle aus Benutzersicht
  - IAM – Topologien
  - Föderation & Provisionierung

Übersicht

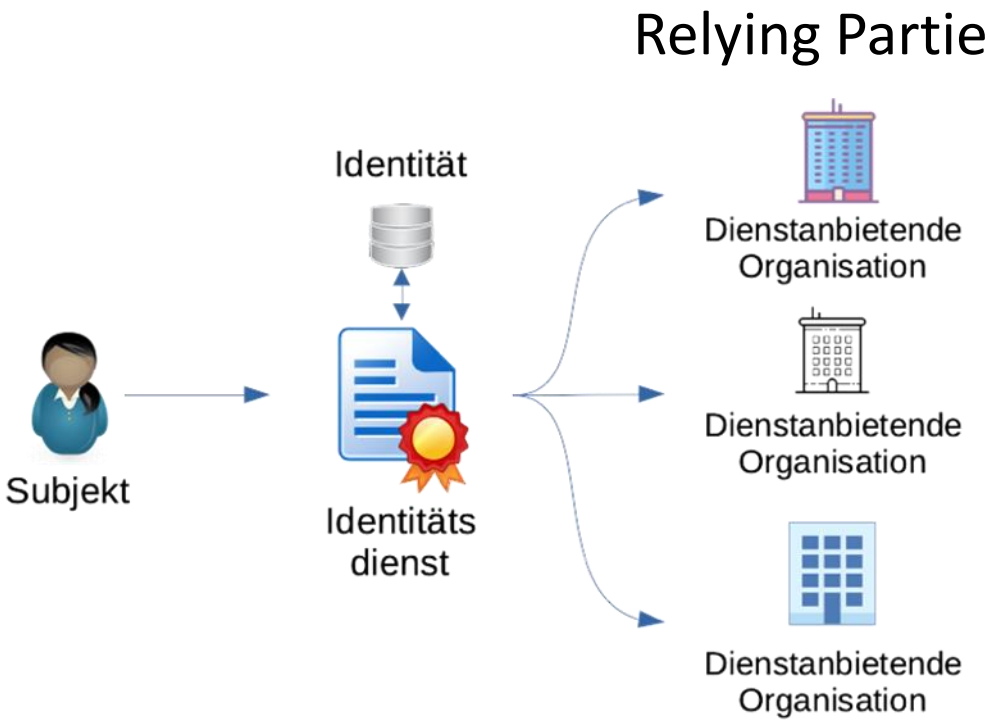
- Taxonomien
  - Modelle aus Benutzersicht
  - IAM – Topologien
  - Föderation & Provisionierung

IAM-Modelle: Benutzersicht 

	Fremdbestimmt	Benutzerzentriert	
		Teilkontrolliert	vollständig kontrolliert
Aussteller der Identität	Identitätsdienst	Identitätsdienst	Subjekt
Kontrolle über die Identität	Identitätsdienst	Subjekt	Subjekt
Beispiele	*Klassische Identitäten (Föderation/ Provisionierung)*	*PKI (X.509 Zertifikat, nPA, Swiss E-ID)*	*SSI (Vision)*

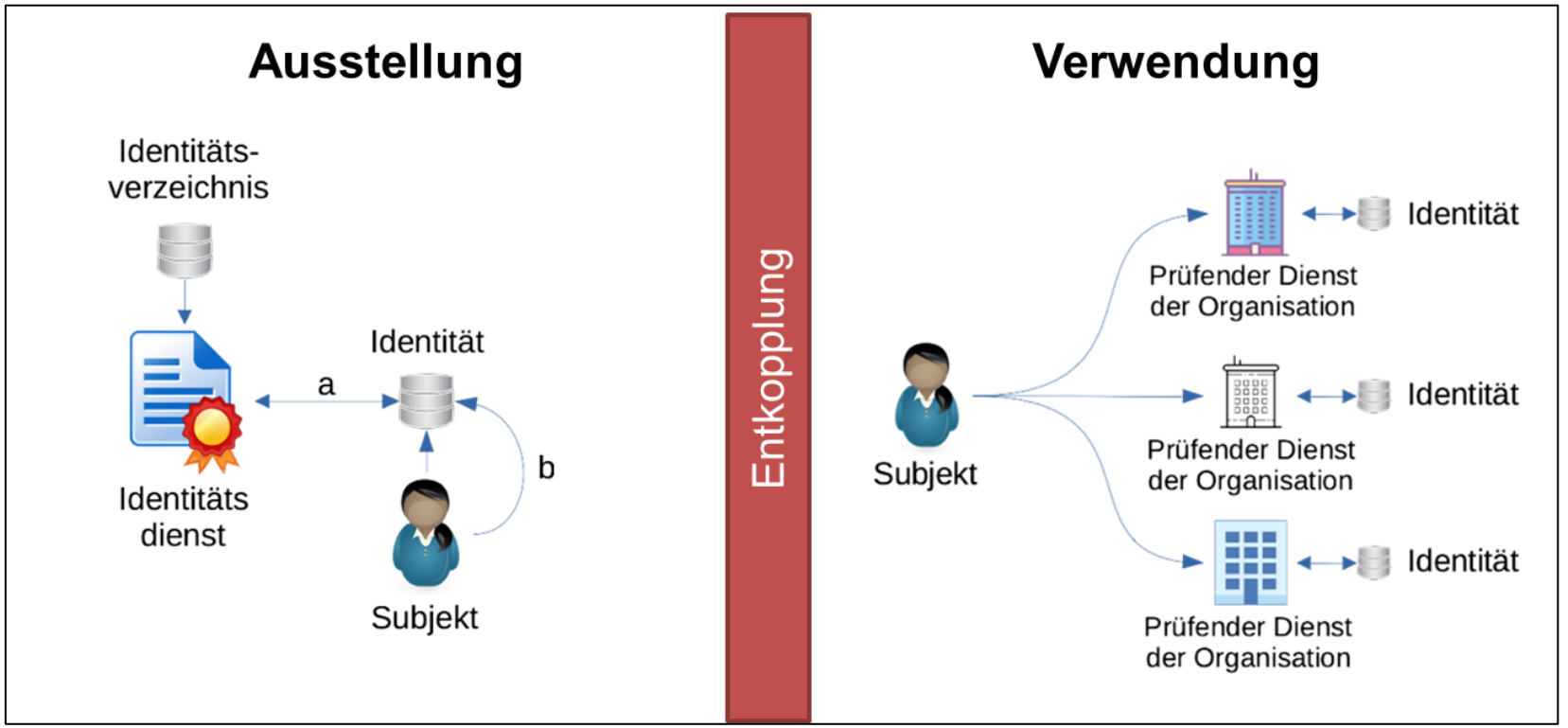
Klassische (digitale) Identitäten

- Der Identitätsdienst kennt den Benutzer und authentifiziert ihn.
  - Gute Usability, meist genügende Sicherheit
- Der Identitätsdienst ist immer involviert, wenn der Benutzer auf eine Relying Party zugreift.
  - Profilbildung möglich, die auf technischer Ebene nur mit sehr grossem Aufwand verhindert werden kann.
- Zentrale Identitätsdienste sind oft Ziele von Cyberattacken, da dort die Benutzerdaten liegen.



Benutzerzentrierte Identitäten

- Der Benutzer kontrolliert seine digitale Identität und damit im Besitz seiner persönlichen Daten (und niemals ein zentraler Dienst).
- Keine zentrale Ablage von Identitätsdaten und Authentifizierungsmitteln
- Der Aussteller (Identitätsdienst) ist in den Prozess der Verwendung der elektronischen Identität nicht involviert und erhält damit keine Nutzungsdaten.

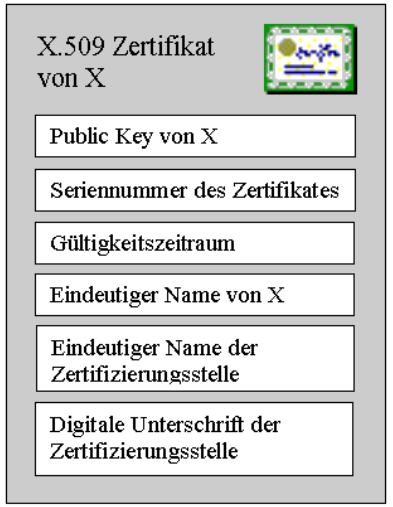


Benutzerzentrierte Identitäten

Benutzerzentrierte (dezentrale) Identitäten sind nicht neu



Neuer deutscher Personalausweis (nPA)



X.509 Zertifikate



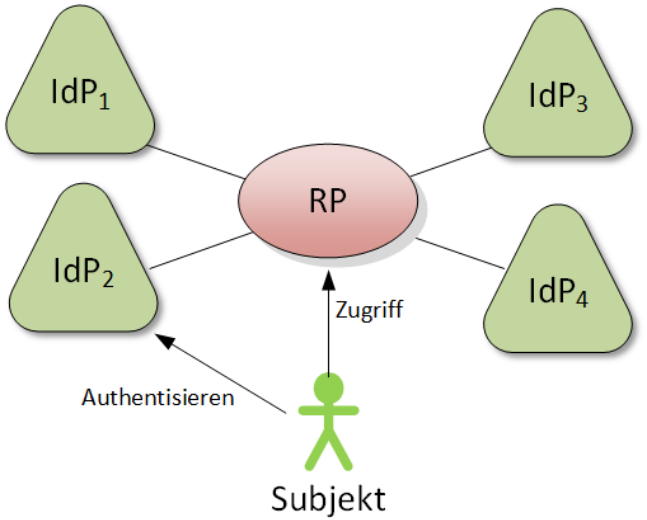
Elektronische Nachweise (Verifiable Credentials) sind neu -> sog. Self Sovereign Identities (SSI)

Übersicht

- Taxonomien
  - Modelle aus Benutzersicht
  - IAM – Topologien
  - Föderation & Provisionierung

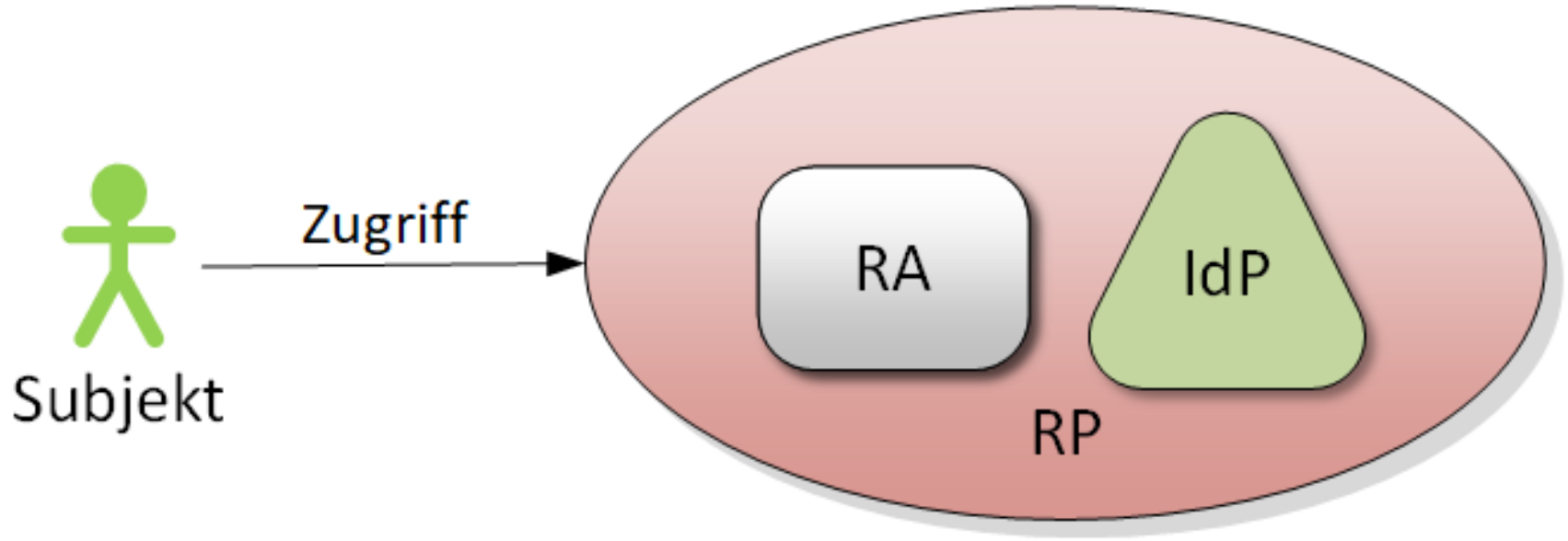
IAM-Modelle: Topologie

- Isolierte (lokale) Identitäten
- Zentrale Identitäten / Identitätsföderation
  - RP zentriert
  - IdP zentriert
  - Full meshed
  - Hub'n Spoke
- Provisionierung



Isolierte Identität: RP mit integriertem IdP

- **Topologie**: Isolierte Identität (lokale Lösung)
- **Benutzersicht**: Fremdbestimmt
- **Bsp**: Webshop – RP mit eingebauter Benutzerverwaltung (IdP und RA)



RP mit integrierten IdP

Aus Sicht des Benutzers:

- Pro RP erhält der Benutzer jeweils eine andere digitale Identität und vielfach ein anderes Authentisierungsmittel.
- Der Benutzer muss dem Dienstleister und dessen Handhabung seiner Identitätsinformationen voll vertrauen. Dies ist für den Benutzer wenig transparent, auch wenn neueste Datenschutzgesetze dies verlangen.

Aus Sicht des Dienstleisters (RP)

- Damit dieser die Identität des Benutzers prüfen kann, muss er einen Identitätsnachweis des Benutzers bei sich ablegen (meist zusammen mit anderen Informationen) und die erhobenen Identitätsinformationen sicher verwalten (drohender Reputationsschaden).
- Um eine zeitgemässe und sicherere Authentisierungsmöglichkeit anbieten zu können, muss der Dienstleister kostenintensive 2-Faktor-Verfahren (z.B. eine SMS an die mobile Nummer des Benutzers senden) selbst implementieren.

Zentrale Identitäten

- **Topologie**: Zentrale Identität
- **Benutzersicht**: Fremdbestimmt

- Bei diesem Modell delegiert die RP die Erstellung und Verwaltung der Identitäten an spezialisierte Unternehmen (IdP).
  - **Federated Identities**
- Die RP verwendet in *ihrer Benutzerverwaltung* Identitäten, die von einer anderen Organisation oder Unternehmen ausgestellt und gewartet werden.
- Beispiele kommen aus dem Bereich ‘Social Login’ (Google, Facebook, Microsoft etc.)
- In einem Enterprise-Umfeld wird vielfach dafür ein zentraler Authentisierungsdienst eingesetzt.

Identitätsmanagement

- Die digitale Identität eines Benutzers umfasst:
  - einen Identifikator,
  - anwendungsunabhängige Attribute,
  - Authentifizierungsmittel & Credentials.
- Im einer digitalen Identität kann sich ein Benutzer authentifizieren.
- Identitätsmanagement umfasst die Daten der Benutzer und ihrer Authentifizierungsmittel & Credentials.

Identifikator	alice
Name	Baumann
Vorname	Alice
Geburtsdatum	16.04.1996
Geburtsort	Bern
Geschlecht	weiblich
E-Mail	alice@bluewin.ch
Passwort	******

Benutzerverwaltung

- die RP muss für jeden Benutzer anwendungsspezifische Settings und Daten ablegen (Datensatz) und die Rechte im System verwalten.
- Jeder Benutzer braucht mindestens einen eindeutigen Identifikator und eine Verknüpfung mit einer oder mehrerer Identitäten für die Authentifizierung.

Identifikator	1234
Studiengang	Informatik
Matrikelnummer	1234 23456 34
Eintrittsdatum	16.04.1996
Rechte	ILIAS, Zoom
Dig. Identität	alice

Benutzerdaten (RP)

Digitale Identität (IdP)

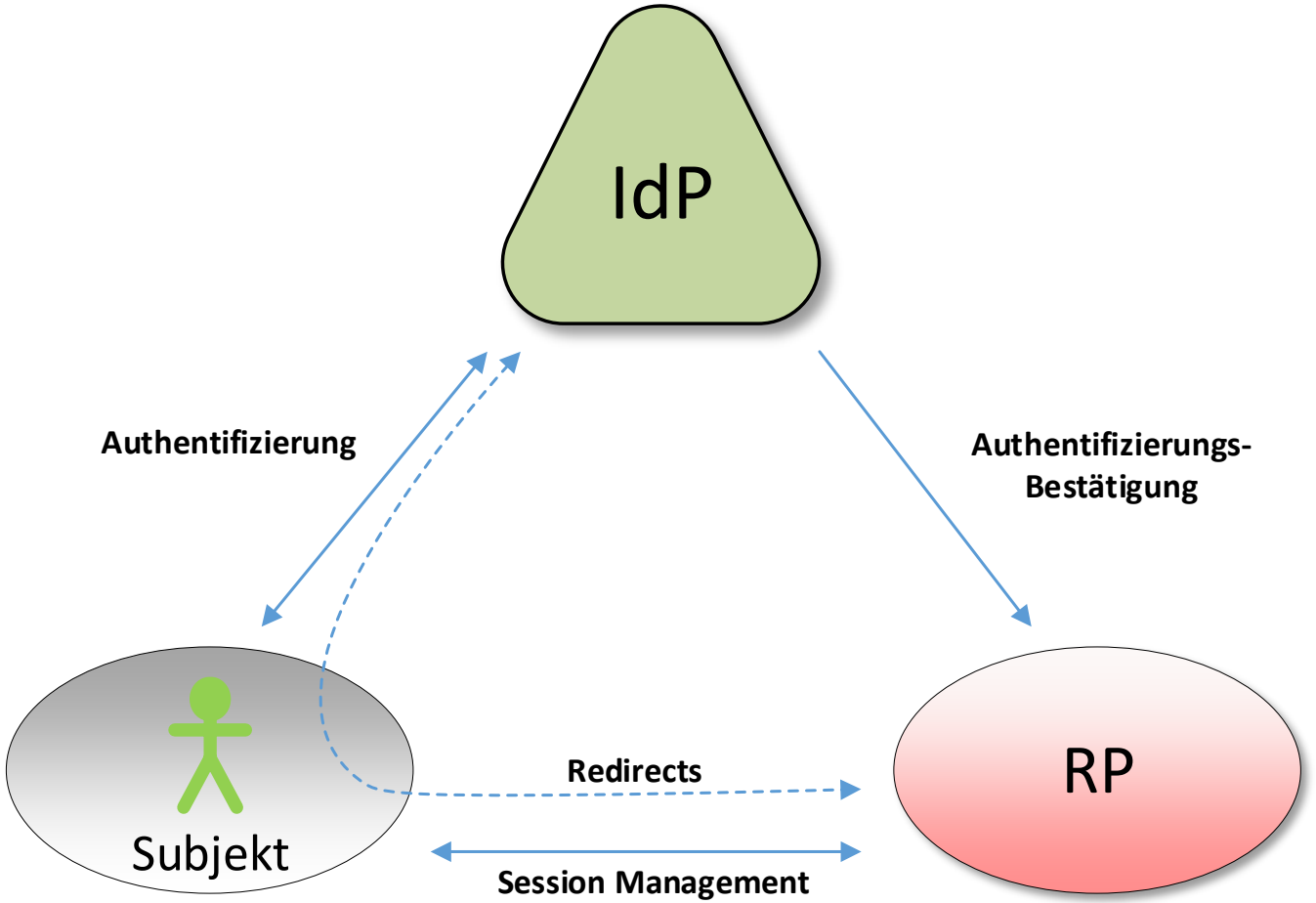
Identifikator	alice
Name	Baumann
Vorname	Alice
Geburtsdatum	16.04.1996
Geburtsort	Bern
Geschlecht	weiblich
E-Mail	alice@bluewin.ch
Passwort	******

Modell einer Identitätsföderation

Synonym: Identity Federation

Voraussetzung ist:

gegenseitiges Vertrauen von IdP und RP



Zentrale Identitäten

Aus Sicht des Benutzers:

- Der Benutzer muss noch eine bzw. wenige Identitäten pflegen und kann diese bei mehreren RPs einsetzen.
- Problem ist die Privatsphäre des Benutzers: da der Identitätslieferant in jeden Authentisierungsvorgang einbezogen wird (Loginfunktion), ist er der Lage ist, sich zu merken, wann und wie häufig ein Benutzer eine RP besucht. (Profilbildung -> gezielte Werbung)
- Der Benutzer muss dem Identitätslieferanten voll vertrauen.
- Der Benutzer wird von dem Identitätsdienst abhängig.

Zentrale Identitäten

Aus Sicht des Dienstleisters (RP):

- Dienstleister delegieren die Identifizierung/Authentisierung einem spezialisierten System von Identitätslieferanten, welchem sie vollständig vertrauen.
  - sie müssen keinen Identitätsnachweis der Benutzer und keine Credentials bei sich ablegen.
  - sie können beglaubigte und damit vertrauenswürdige Attribute beziehen.
  - sie brauchen keine Prozesse fürs Identitätsmanagement, wie z.B. Passwort zurücksetzen

Aus Sicht des Identitätslieferanten (IdP):

- Da aus verschiedenen Bereichen Daten von Benutzern anfallen, lohnt es sich die Nutzerdaten zu sammeln und monetär zu verwenden.
- Durch mehrdimensionale Profile können leistungsstarken Targeting- und Profiling-Tools eine sehr effiziente Form der Überwachung ermöglichen.
- Aggregierte Datenbestände werden zunehmend zu lohnenden Angriffszielen von Hackern.

Föderations-Modelle

- Es können verschiedene Topologien unterschieden werden:
  - RP zentriert
  - IdP zentriert
  - Full meshed
  - Hub’n Spoke

- Aber auch Mischformen sind möglich und üblich.

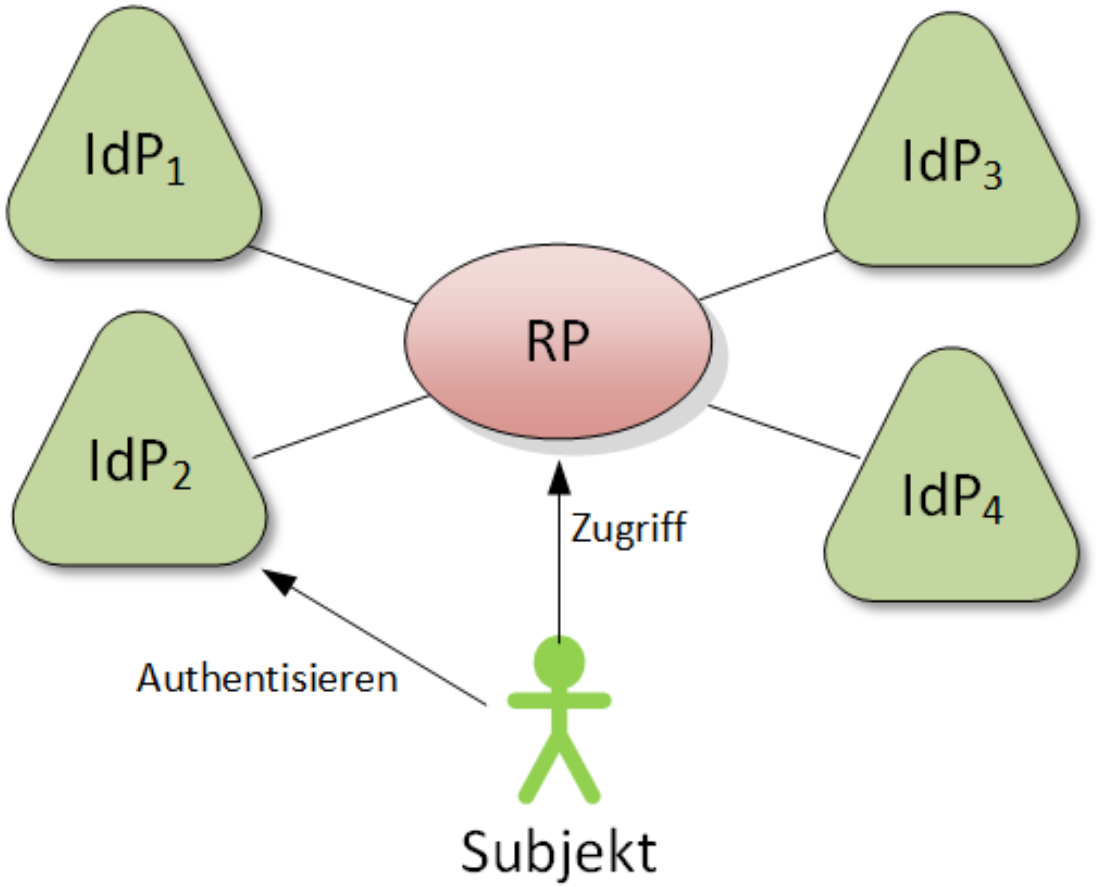
RP-zentriertes Modell

Vorteil für RP:

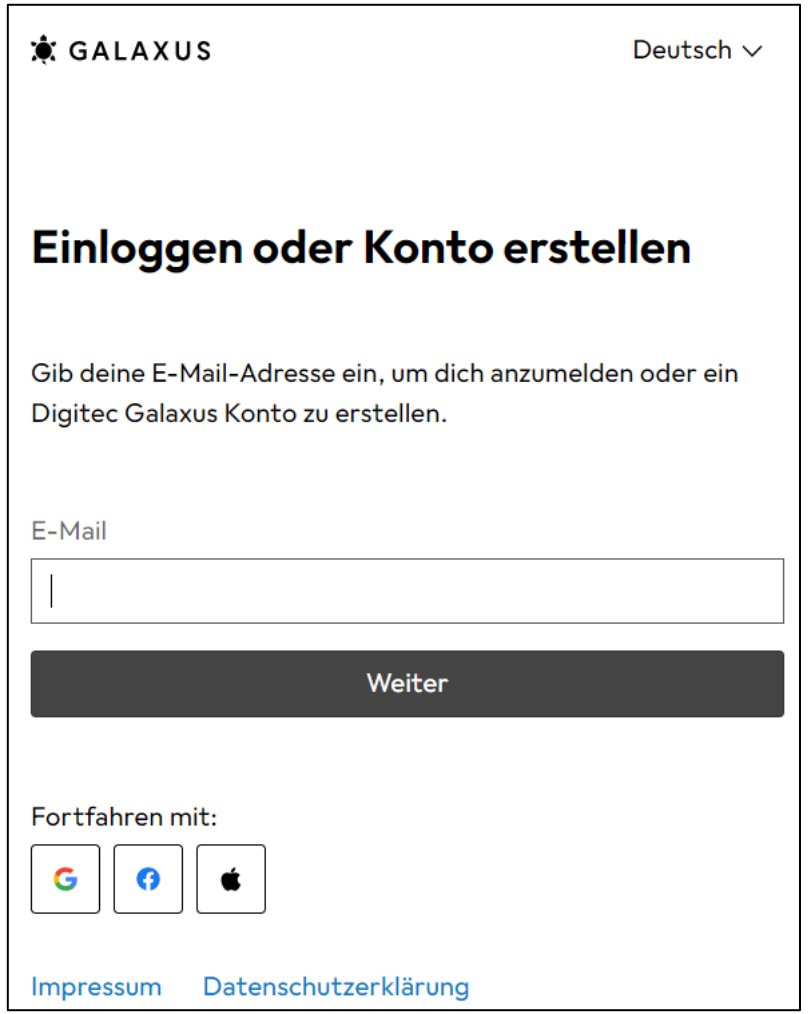
- Kann Identitäten von mehrere IdPs verwenden (grössere Reichweite)

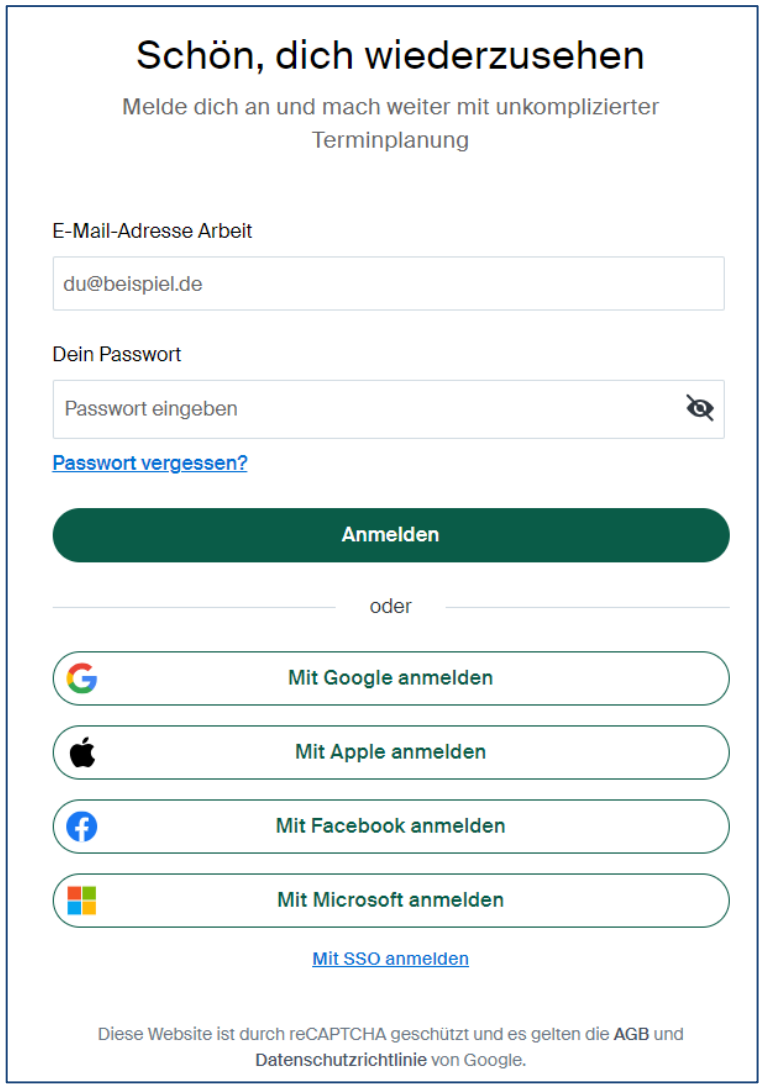
Nachteil für RP:

- Muss mit mehreren IdPs kommunizieren, die u.U. unterschiedliche Ausprägungen der Identitäten haben und evtl. unterschiedliche Protokolle verwenden (Standardisierungsbedarf)



Beispiele RPs eigenem und mit externen IdPs

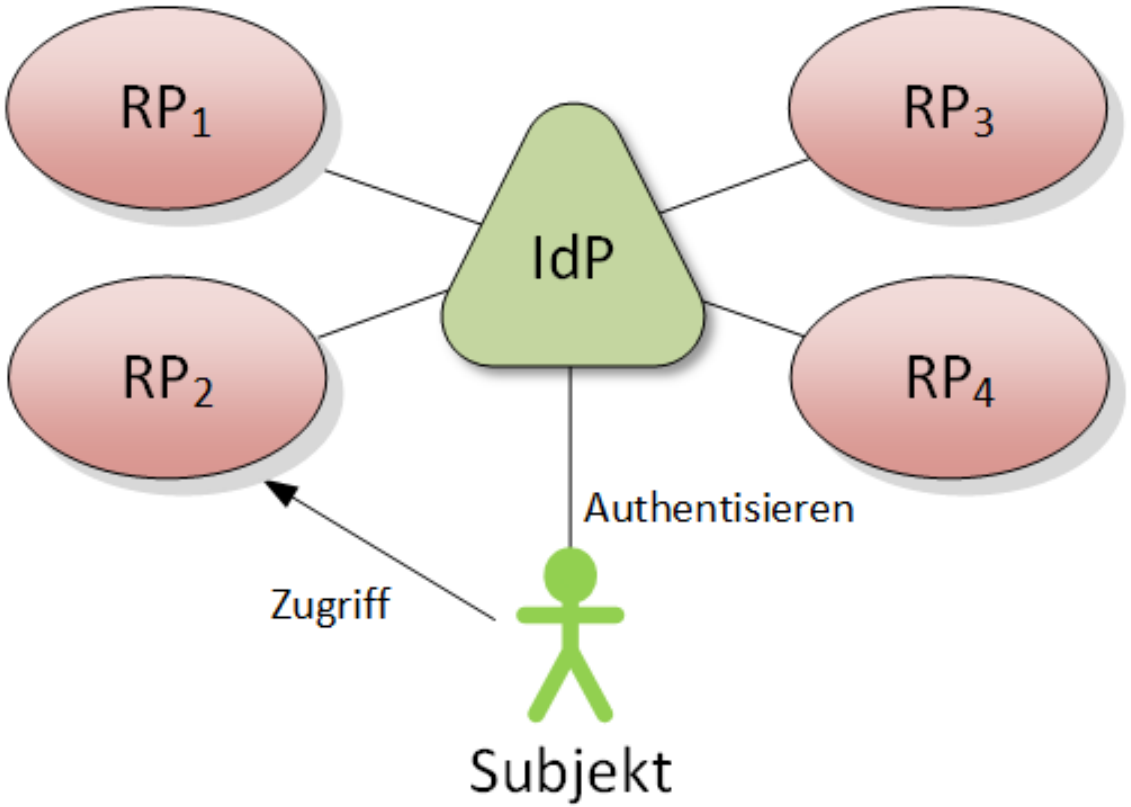




https://doodle.com/

IdP-zentriertes Modell

- Zentraler IdP für mehrere Applikationen
- Vorteil für RP
  - Nur ein Kommunikationspartner (ein Identitätstyp, ein Protokoll)
- Vorteil für Subjekt (User)
  - Nur eine Identität, SSO möglich
- Nachteil für Subjekt
  - IdP kann Profile bilden
- Beispiel: Student-Login, Google, Apple, Microsoft, …

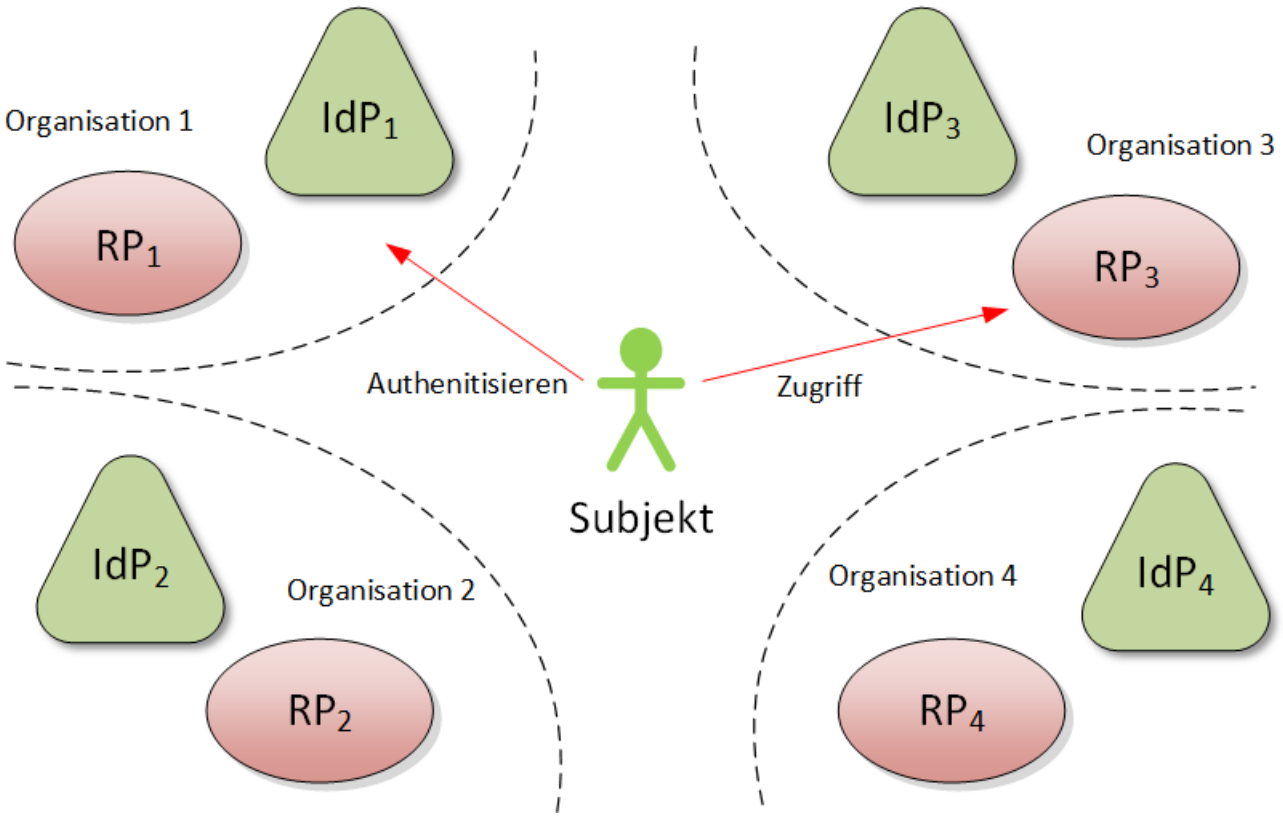


Cross domain modell

In einem *full-meshed* Modell föderieren mehrere Organisationen gegenseitig Identitäten über ihre Organisationsgrenzen hinweg. Jede Organisation tauscht alle notwendigen Identitätsinformationen der eigenen Systeme mit den Partnerorganisationen aus.

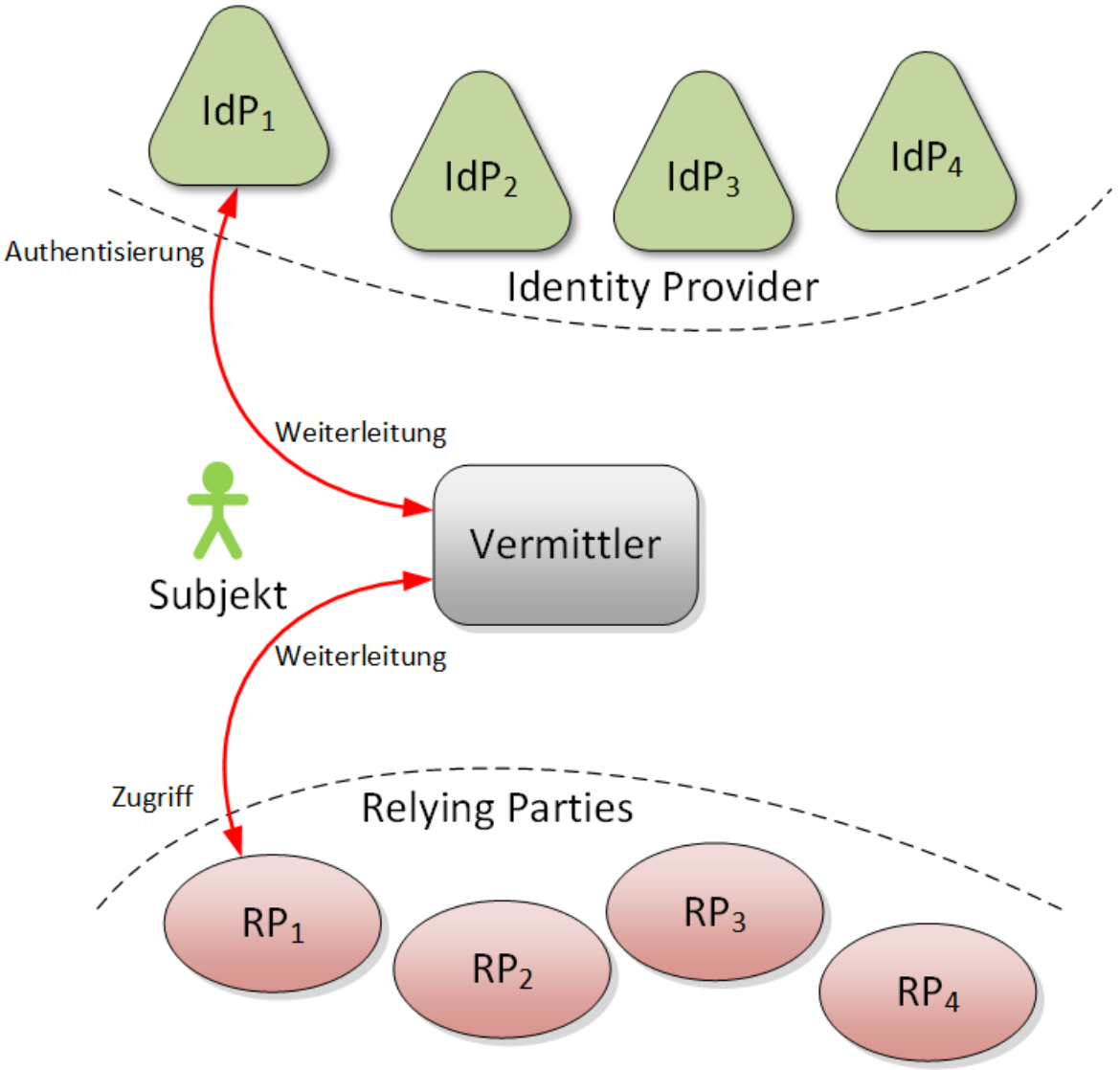
Frage: Was sind Vor- und Nachteile von einem solchen Modell?

Beispiel: Switch-AAI eduroam



Hub’n Spoke

- Ein Hub-'n'-Spoke-Modell basiert auf einer zentralen Vermittlerinfrastruktur - dem *Broker*.
- Alle beteiligten Parteien **vertrauen diesem *Vermittler***.
- Identitätslieferanten (*IdP*) und -konsumenten (*RP*) kommunizieren nicht mehr direkt miteinander. Sie tauschen ihre Nachrichten über den *Vermittler* aus, welcher diese prüft und an den richtigen Empfänger weiterleitet.



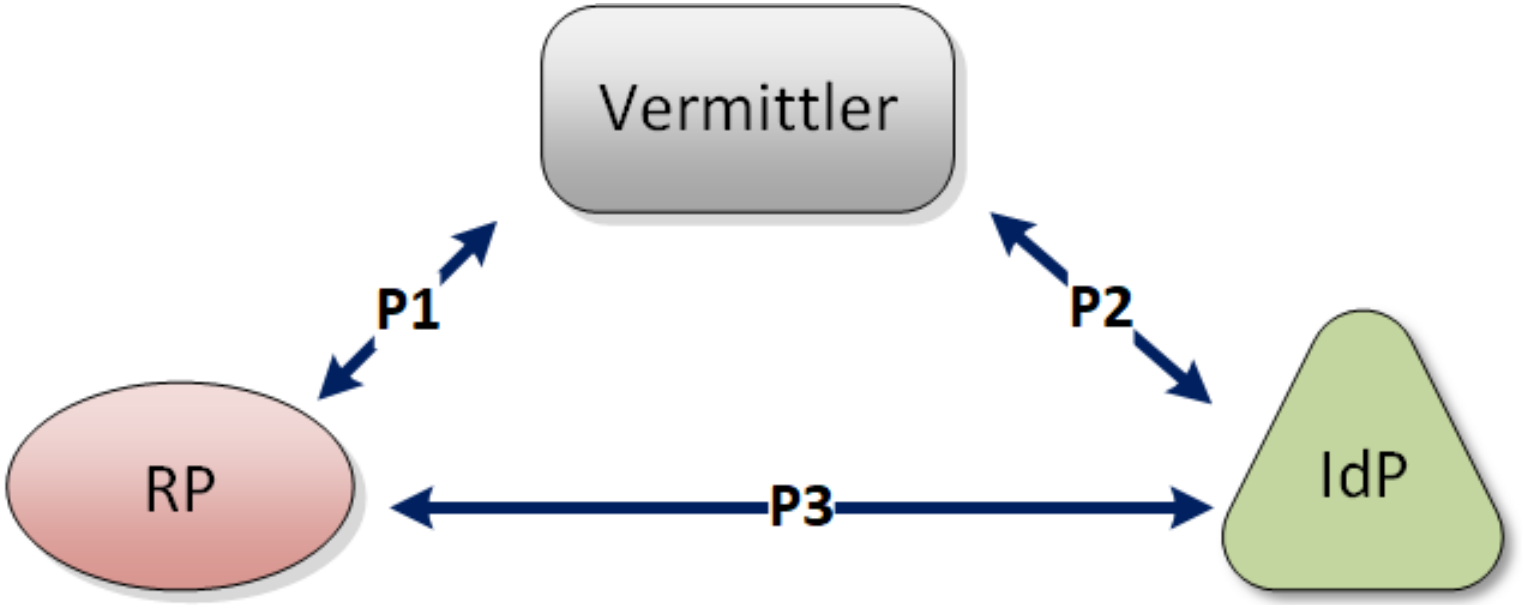
Vermittler

- Ein **Vermittler** bietet gemeinsame Dienste für alle anderen IAM-Dienstanbieter und Relying Parties in einer Identitätsföderation nach dem Hub-'n'-Spoke Modell an.
- Mögliche zentrale Dienste:
  - Metadatenverwaltung,
  - IdP-Discovery,
  - Identity Linking,
  - Transformation der Authentifizierungs- und Attributbestätigung
  - Protokolltransformation
  - …
- Ein integraler Bestandteil eines Vermittlers ist immer ein *Authentication Proxy*.
- Ein Vermittler kann optional einen IdP enthalten.
- **Synonyme**: Hub, Broker, Super-IdP

Authentication Proxy

Ein **Authentication Proxy** verbindet zwei Protokollabschnitte und bildet damit einen Protokoll-endpunkt. Er kann eine Authentifizierungsanfrage transformieren und/oder anpassen und diese an einen IdP weiterleiten.

Ende-zu-Ende-Verschlüsselung daher nur schwierig umzusetzen.



Wiederholungsfragen / Diskussion

1. Welche Kriterien gibt es zur Kategorisierung von IAM-Systemen?

2. Machen Sie Aussagen zum Schutz der Daten und Privatsphäre bei den verschiedenen Topologien.

3. Welche IAM-Topologien sind vorteilhaft für eine RP? Welche IAM-Topologien sind vorteilhaft für den Benutzer ?

4. Welche Vor- und Nachteile hat ein vermittlerbasiertes Modell (Hub’n Spoke)?

5. Warum ist die Verwendung von Standards wichtig?

Provisionierung

- **Provisionierung** bezieht sich auf die Erstellung, Pflege und Deaktivierung von Identitäten (Benutzerobjekten) und deren Attributen, wenn sie in **mehreren** IAM-Systemen oder Anwendungen vorhanden sind.
- oft als Reaktion auf automatisierte oder interaktive Geschäftsprozesse.
- Bei der Provisionierung werden **Kopien** oder **Referenzen von Identitäten** von einer Datenquelle (HR, CRM, StudAdmin, …) in ein IAM-System transportiert.
  - Es können auch Berechtigungen transportiert werden.

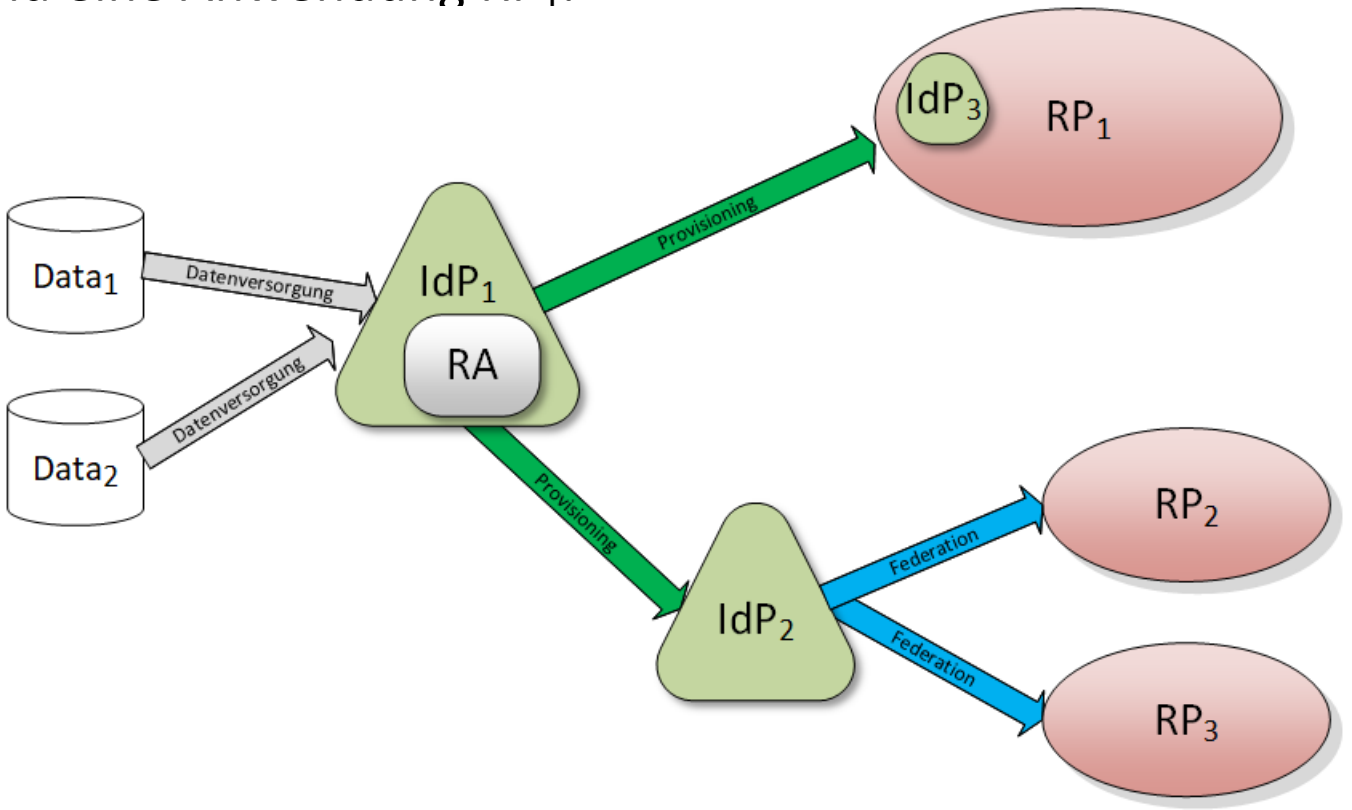
- SCIM (System for Cross-domain Identity Management) ist ein offener Standard, der die Automatisierung der Provisionierung (user provisioning) ermöglicht.

Provisionierung – Beispiel

Datenversorgung: Primärer IdP_1 mit RA bekommt Daten aus 2 Datenquellen

Provisionierung: IdP_1 versorgt einen IdP_2 und eine Anwendung RP_1.

Föderation: IdP_2 versorgt RP_2 und RP_3 mit föderierten Identitäten.



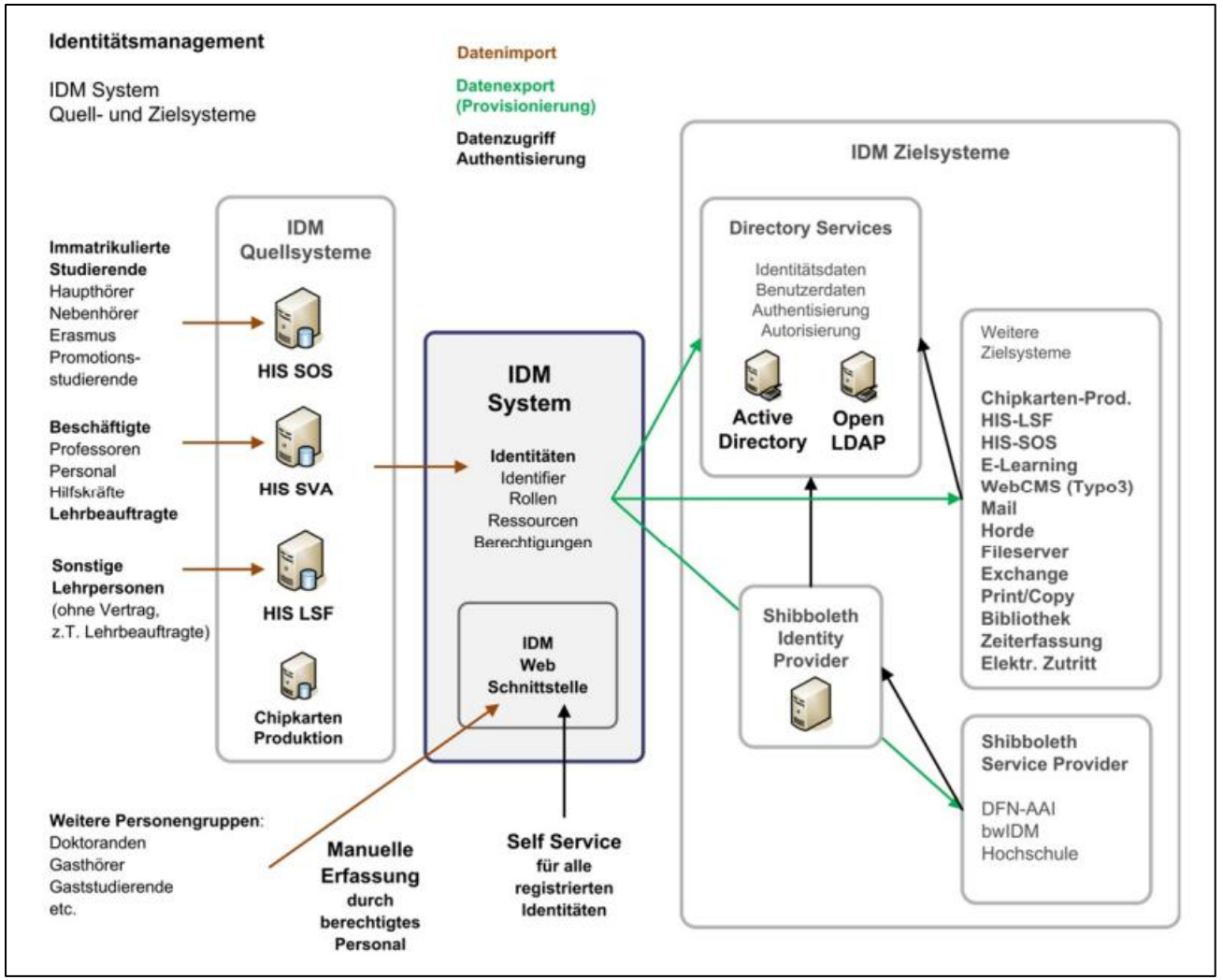
2 Kategorien von Provisionierungssystemen

- **Zentrales System**:
  - Provisionierungs-Anfragen und -Änderungen werden in direkt angeschlossenen Systemen ausgeführt.
  - (Meta-) Verzeichnisdienste, wie LDAP oder Active Directory (AD).

- **Verteiltes System**:
  - Es gibt keine zentrale «Identitätsstelle».
  - Identitätsinformationen werden entspr. von Vertrauensbeziehungen verteilt.
  - Die angeschlossenen Systeme haben eine eigene Benutzerverwaltung.

- Meistens findet man eine Kombination aus beiden Kategorien.

Beispiel: PH Heidelberg



- Verschiedenen Datenquellen werden im IDM/IAM-System konsolidiert und dann an die verschiedenen IdP & Directory Systeme provisioniert

- https://www.ph-heidelberg.de/fileadmin/de/hochschule/verwaltung/AmtlicheBekanntmachungen/2016/IDMAHochschulsatzung_PHHD_14.12.2016_AnlageA.pdf

Beispiele

- **Auto-provisioning**
  - Die Studentenverwaltung wird überwacht und es werden automatisch neue Benutzer auf Systemen und Anwendungen angelegt, wenn neue Studentendatensätze in der StudAdmin-Datenbank erscheinen.
- **Auto-deactivation**
  - Die HR-Anwendung wird überwacht und Benutzerobjekte auf anderen Systemen und Anwendungen automatisch deaktiviert, wenn ein Mitarbeiterdatensatz entweder verschwindet oder in der HR-Datenbank als inaktiv markiert wird.

Föderation vrs Provisionierung

Föderation

Ermöglicht den Subjekten den Zugriff auf verschiedene RPs mittels einer vertrauenswürdigen Identität.

- Zentraler Vermittler/IdP: Muss immer verfügbar sein.
+ Ermöglicht Single-Sign-On
+ Identitätsverwaltung zentral und unabhängig von der Anwendung.

Provisionierung

Verwaltung und Verteilung von Benutzeridentitäten und deren Zugriffsrechten innerhalb von Systemen

+ Identitäten lokal, weniger Abhängigkeiten
- Jedes angeschlossene System/Anwendung muss (De-)Provisionieren.